

EXECUTIVE THIRD-PARTY RISK DECISION

Vendor Renewal Decision Memo

Summit Technology Solutions (STS)

Organization	Northstar Financial Group (fictional)
Vendor	Summit Technology Solutions (STS) - fictional managed IT provider
Assessment Type	Critical Third-Party / Vendor Cybersecurity Risk Assessment
Analyst	Ryan Bryant
Decision	Conditional Go - renewal blocked pending mandatory controls

Portfolio note: This document is a fictional cybersecurity assessment simulation. No real company or vendor was assessed.

Decision at a Glance

Vendor Criticality	Critical
Current Weighted Risk	4.1 / 5 - Severe High / Critical range
Target Residual Risk	2.1 / 5 - Moderate
Recommended Decision	Conditional Go
Renewal Condition	Mandatory controls executed and validated before effective date
Fallback Decision	No-Go and transition planning if any renewal blocker is refused

Executive Recommendation

Do not renew STS under the existing agreement. Proceed only after critical contractual protections and technical safeguards are in place.

Why This Vendor Matters

STS administers servers, firewall and VPN infrastructure, supports Microsoft 365, maintains remote connectivity, and participates in continuity and incident-response activities. A vendor outage could delay operations and recovery; a vendor compromise could provide a trusted administrative path into Northstar and affect confidentiality, integrity, and availability at the same time.

Top Renewal Blockers

- Defined 72-hour notification requirement for relevant suspected or confirmed incidents, measured from discovery.
- Notification before STS completes its full investigation when an incident reasonably could affect Northstar.
- Guaranteed preservation and delivery of Northstar-relevant security logs and evidence.
- MFA-gated privileged access before renewal; no direct privileged MFA exemption.
- Immediate separation-time revocation of interactive and customer access.
- Northstar-controlled ability to revoke STS privileged access without losing ownership/control of the environment.
- Complete disclosure of material subprocessors and 30-day advance notice of material changes.
- Defined recovery capabilities for STS critical downstream providers.
- Guaranteed Northstar-specific data, configuration, credential, and documentation portability at exit.

Negotiated Protections

Incident notification: Northstar accepted 72 hours only when measured from discovery of an incident that reasonably could affect Northstar; final written report required even if Northstar is ultimately unaffected. Result: Agreement.

Logs & evidence: Northstar accepted scoped exports rather than direct multi-tenant platform access; 24-hour incident delivery, 48-hour routine audit delivery, and preservation on investigation notice. Result: Agreement.

Privileged MFA: Northstar rejected. STS revised to an MFA-protected privileged access gateway within 45 days, named engineers, logged sessions, and legacy-tool replacement within six months. Result: Agreement pending validation.

Material subprocessors: Northstar required 30-day advance notice, documented security objection rights, and termination of affected services without unreasonable penalty if unresolved. Result: Agreement with clarification.

Exit & portability: Northstar accepted STS ownership of generic IP but required all Northstar-specific configurations, data, credentials, architecture records, service inventories, defined migration pricing, and validated handoff before deletion. Result: Agreement.

Residual Risk Decision

If all mandatory controls are implemented and validated, the weighted target residual risk falls from approximately 4.1/5 to 2.1/5. The relationship would remain important and would still require continuous third-party oversight, but the remaining exposure would be within a Moderate range for this simulation.

Management Acceptance

Approval should explicitly acknowledge continued dependence on STS, its downstream cloud providers, a 72-hour relevant-incident notification window, remaining recovery-testing gaps, and legitimate STS ownership of generic proprietary tooling.

Required Executive Actions

- Authorize Legal and Procurement to incorporate the negotiated cybersecurity requirements into the renewal agreement.
- Require Security to validate privileged MFA controls, access revocation, log/evidence delivery, and transition readiness before the renewed contract becomes effective.
- Require STS to provide a dated remediation plan for remaining High and Moderate findings.
- Require quarterly privileged-access and material-subprocessor reviews after renewal.
- Authorize vendor-transition planning if STS refuses or fails a mandatory renewal requirement.

Decision Statement

Recommended decision: **CONDITIONAL GO**. Renewal is permitted only after mandatory terms are executed and validated. If STS does not accept or implement the renewal blockers, Northstar should decline renewal and initiate a controlled transition to an alternate provider.